

README — KIT GQM+PRAGMATIC CAPEC-ESP

Guía de Inicio Rápido y Documentación del Sistema

Versión 1.0 • Abril 2026

«Los kits de ciberseguridad, como los botiquines, tienen dos tipos de usuarios: los que los abren antes de que ocurra algo, y los que los abren después. Este README está escrito pensando en los primeros — aunque está diseñado para sobrevivir el uso de los segundos.»

¿QUÉ ES ESTE KIT?

El **Kit GQM+PRAGMATIC CAPEC-ESP** es un sistema de medición de la postura de ciberseguridad basado en:

- CAPEC v3.9 (Common Attack Pattern Enumeration and Classification — MITRE): El catálogo de referencia de 559 patrones de ataque, con indicadores de probabilidad y severidad intrínsecos
- GQM (Goal-Question-Metric — Basili, Caldiera & Rombach, 1994): Metodología de definición de métricas con trazabilidad directa a objetivos organizacionales
- PRAGMATIC (Hubbard & Seiersen, 2016): Marco de evaluación de calidad de métricas de seguridad según 9 criterios

El resultado es un conjunto de **24 indicadores** distribuidos en **8 dominios** que producen un **Índice Global de Madurez CAPEC (IGM-CAPEC)** en escala 0–5, con trazabilidad completa a NIS2, ENS, DORA, ISO 27001 y NIST CSF 2.0.

CONTENIDO DEL KIT

Archivo	Descripción	Audiencia principal
GQM-A-marco-integrativo.md	Árbol GQM completo con 24 métricas en 8 dominios	Técnica / Académica
GQM-B-matriz-pragmatic.md	Evaluación PRAGMATIC (9 criterios × 24 métricas)	Técnica / Gestión
GQM-C-narrativa.md	Contexto, motivación y argumentación propositiva	Directiva / Gestión
GQM-D-mapeo-normativo.md	Trazabilidad de cada indicador a marcos regulatorios	Cumplimiento / Legal
GQM-E-excel-IGM-ROSI.md	Especificación Excel (8 hojas, fórmulas completas)	Analistas / CISO
GQM-F-reporte-ppt.md	Especificación PowerPoint (18 slides + backup)	CISO / Comunicación
GQM-G-README.md	Este documento	Todos

INICIO RÁPIDO EN 5 PASOS

PASO 1: Identificar el perfil de la organización (15 minutos)

Antes de aplicar el kit, definir:

- ☐ ¿La organización es entidad esencial o importante según NIS2?
- ☐ ¿Cuál es la categoría ENS aplicable (Alta / Media / Básica)?
- ☐ ¿La organización tiene activos OT/ICS? (ajusta el peso w_{OT})
- ☐ ¿La organización tiene sistemas de IA en producción? (ajusta w_{AI})
- ☐ ¿Los datos manejan requisitos de confidencialidad > 10 años? (activa PQC)

PASO 2: Seleccionar los documentos pertinentes

Si eres CISO o Director de Seguridad:

→ Empieza por GQM-C-narrativa.md (contexto) → GQM-A-marco-integrativo.md (métricas) → GQM-E-excel-IGM-ROSI.md (implementación)

Si eres responsable de cumplimiento / GRC:

→ Empieza por GQM-D-mapeo-normativo.md (requisitos) → GQM-A-marco-integrativo.md (métricas)
→ GQM-B-matriz-pragmatic.md (priorización)

Si eres analista técnico:

→ Empieza por GQM-A-marco-integrativo.md (métricas completas) → GQM-E-excel-IGM-ROSI.md (implementación) → GQM-B-matriz-pragmatic.md (evaluación de calidad)

Si vas a presentar al Consejo:

→ Empieza por GQM-C-narrativa.md (argumentación) → GQM-F-reporte-ppt.md (presentación) → GQM-E-excel-IGM-ROSI.md (datos para los slides)

PASO 3: Recopilar datos para los 50 indicadores

Utilizar la estructura de la Hoja DATOS_ENCUESTA del Documento E. Para cada pregunta:

1. Identificar la fuente de datos (SIEM, SOAR, escáner de vulnerabilidades, plataforma de phishing, etc.)
2. Obtener el valor actual con la mayor precisión posible
3. Registrar la fecha del dato y la fuente de verificación
4. Anotar el nivel de confianza (1=Baja, 2=Media, 3=Alta)

Nota sobre datos no disponibles: Si un dato no está disponible, asignar el valor mínimo (0 o 1) con nivel de confianza 1. No dejar celdas vacías: el modelo necesita un valor para calcular. La ausencia de dato es, en sí misma, información sobre madurez.

PASO 4: Calcular el IGM-CAPEC

Implementar las fórmulas del Documento E en Excel o Google Sheets:

5. Abrir Excel → Crear libro con las 8 hojas especificadas
6. Introducir datos de DATOS_ENCUESTA
7. Las fórmulas de IGM_CAPEC calculan automáticamente el índice
8. Verificar que SUMA(pesos) = 1,00 en la hoja de pesos
9. Generar los gráficos del DASHBOARD

PASO 5: Interpretar y actuar

IGM-CAPEC	Nivel	Interpretación	Acción inmediata
4,0 - 5,0	● AVANZADO	Programa maduro con mejora continua	Compartir mejores prácticas; mantener inversión
3,0 - 4,0	● ESTABLECIDO	Controles implementados con brechas menores	Optimizar dominios por debajo de 3,5
2,0 - 3,0	● EN DESARROLLO	Controles básicos; brechas significativas	Implementar Top 3 acciones del PLAN_ACCION
0,0 - 2,0	● INICIAL	Exposición alta; acción urgente	Escalar al Consejo; plan de emergencia

ÁRBOL DE DECISIÓN DE USO

¿Para qué necesitas el kit?

- Medir la postura de seguridad actual
 - └ Documentos: A + E + F (Pasos 1-5)
- Demostrar cumplimiento normativo
 - └ Documentos: D + A + F (foco slides 11-14)
- Priorizar inversión en seguridad
 - └ Documentos: E (ROSI) + B (PRAGMATIC) + F (slides 10+13)
- Investigación académica / publicación
 - └ Documentos: A + B + C (con todas las referencias)
- Auditoría / due diligence
 - └ Documentos: D + A + E (evidencias verificables)
- Comunicación al Consejo
 - └ Documentos: C + F + E (datos para gráficos)

ADAPTACIÓN POR SECTOR NIS2

Sectores Esenciales (Anexo I NIS2)

Sector	Ajustes de peso recomendados
Energía	$w_{OT} = 0,15$ (t); $w_{AI} = 0,03$ (t)
Transporte	$w_{OT} = 0,12$ (t); $w_{NET} = 0,12$ (t)
Banca / Finanzas	$w_{SW} = 0,22$ (t); $w_{SC} = 0,18$ (t) — DORA es ley
Infraestructura mercados financieros	$w_{GOV} = 0,25$ (t); $w_{SW} = 0,20$ (t)
Salud	$w_{IS} = 0,18$ (t); $w_{GOV} = 0,22$ (t) — RGPD + NIS2
Agua	$w_{OT} = 0,18$ (t); $w_{HW} = 0,10$ (t)
Infraestructura digital	$w_{SW} = 0,22$ (t); $w_{SC} = 0,18$ (t)

Sectores Importantes (Anexo II NIS2)

Para entidades de Anexo II, los pesos por defecto son adecuados. Si la organización tiene activos OT, aplicar los ajustes del sector correspondiente.

Administración Pública (ENS)

Para entidades del sector público español:

- Verificar categoría ENS (Alta / Media / Básica)
- Los controles ENS son exigibles según categoría; ajustar umbrales de verde/rojo en consecuencia
- El CCN-CERT y el INCIBE son las fuentes de benchmarking para el sector público

FRECUENCIA DE REVISIÓN RECOMENDADA

Elemento	Frecuencia	Responsable
Métricas operacionales (MTTD, MTTC, tasa phishing)	Mensual	SOC / Analista GRC
Métricas de cobertura (SBOM, firmware, segmentación)	Trimestral	Arquitecto de Seguridad
IGM-CAPEC completo (50 preguntas)	Trimestral	CISO + equipo
Reporte al Consejo con IGM-CAPEC	Trimestral	CISO
Revisión de pesos y umbrales	Anual	CISO + CRO
Actualización por nueva versión CAPEC	Por release MITRE	Arquitecto de Seguridad
Revisión de mapeo normativo	Por cambio regulatorio	GRC / Legal

CONTROL DE CALIDAD DE LOS DATOS

Antes de calcular el IGM-CAPEC, verificar:

- ☐ Todos los 50 campos de DATOS_ENCUESTA tienen valor (0 o dato real)
- ☐ Los porcentajes están en formato decimal (0,75 para 75%, no 75)
- ☐ Los valores Likert son enteros entre 1 y 5
- ☐ Los valores binarios son exactamente 0 o 1
- ☐ La suma de pesos en IGM_CAPEC es exactamente 1,00
- ☐ Las fechas de los datos no tienen más de 90 días de antigüedad
- ☐ El nivel de confianza de al menos el 70% de los datos es ≥ 2

Flag de advertencia: Si más del 30% de los datos tiene nivel de confianza 1 (Baja), el IGM-CAPEC puede estar subestimado o sobreestimado. En el reporte al Consejo, indicar el nivel de confianza del índice junto al valor.

PREGUNTAS FRECUENTES

¿Podemos usar este kit sin haber leído el informe CAPEC anterior?

Sí, los documentos A y C incluyen el contexto suficiente. El informe CAPEC es material de profundización para quienes quieran comprender la base empírica de los indicadores.

¿Los 24 indicadores son todos obligatorios?

No. Para una primera implementación, se recomienda comenzar con los 9 indicadores de score PRAGMATIC $\geq 4,5$ (Documento B, Ranking posiciones 1-6). Cubren el 80% del valor informativo con el 30% del esfuerzo.

¿Podemos adaptar los pesos del IGM-CAPEC?

Absolutamente sí. Los pesos por defecto están justificados para una organización genérica española NIS2. Los ajustes sectoriales recomendados están en este README. Documentar cualquier cambio de pesos en el campo de notas de la hoja INICIO para garantizar comparabilidad histórica.

¿Este kit reemplaza a ISO 27001, ENS o NIS2?

No. Es complementario. Los marcos de cumplimiento establecen qué hacer. El kit GQM+PRAGMATIC CAPEC mide si lo que se hace funciona —y lo hace con métricas que tienen sentido para los adversarios, no solo para los auditores.

¿Con qué herramienta recomiendan implementar el Excel?

Microsoft Excel 365 (versión completa) o Google Sheets. Las fórmulas de matriz dinámica del Documento E requieren versión Excel 2019 o posterior. Para versiones anteriores, sustituir ORDENAR() por ordenación manual y BUSCARV() con rangos ajustados.

¿El kit tiene validación estadística?

El kit aplica GQM (metodología validada académicamente desde 1994) y PRAGMATIC (validado en múltiples estudios desde 2016). El IGM-CAPEC como índice compuesto se recomienda validar con Alpha de Cronbach antes de su uso como instrumento de investigación formal (ver Documento B del kit de encuesta, sección 3.2).

LIMITACIONES CONOCIDAS Y TRABAJO FUTURO

Limitaciones actuales:

- CAPEC v3.9 no incluye aún entradas formales para Prompt Injection en LLMs, AI Model Poisoning ni

ataques HNDL cuánticos – las métricas M-AI-1.x y M-PQC-1.x se basan en NIST AI 100-2e2025 y NIST IR 8547 hasta que MITRE las formalice

- Los valores de referencia sectorial para benchmarking son estimaciones basadas en ENISA NIS360 2024, IBM Cost of Data Breach 2024 y INCIBE 2025; no provienen de una muestra empírica española validada – esta es precisamente la brecha que la aplicación masiva del kit vendría a cerrar
- Los pesos del IGM-CAPEC son juicio experto; requieren validación con análisis factorial confirmatorio sobre muestra representativa

Trabajo futuro propuesto:

- Estudio empírico nacional con $n \geq 400$ organizaciones para validar los pesos y generar benchmarks sectoriales españoles
- Integración con el European Cybersecurity Index (ENISA) en desarrollo
- Extensión del kit para incluir patrones CAPEC de IA adversarial cuando MITRE los formalice (estimado: 2026-2027)
- Desarrollo de la versión automatizada del kit en formato web (API CAPEC + dashboard online)

LICENCIA Y USO

Licencia: Creative Commons Attribution-NonCommercial-ShareAlike 4.0 International (CC BY-NC-SA 4.0)

Puede: Usar libremente, adaptar y distribuir el kit para fines no comerciales, siempre que cite la fuente y mantenga la misma licencia en derivados.

No puede: Usar el kit con fines comerciales sin autorización expresa. Presentar el kit o derivados significativos como trabajo propio sin citar la fuente.

Cita recomendada (APA 7ª edición):

Kit GQM+PRAGMATIC CAPEC-ESP (2026). Sistema de indicadores de ciberseguridad basado en CAPEC con metodología GQM y evaluación PRAGMATIC. Aplicación territorial España (v1.0).

Basado en: MITRE CAPEC v3.9; Basili, V., Caldiera, G. & Rombach, H.D. (1994).

The goal question metric approach. Encyclopedia of Software Engineering;

Hubbard, D. & Seiersen, R. (2016). How to Measure Anything in Cybersecurity Risk.

Wiley. CC BY-NC-SA 4.0.

REFERENCIAS DE LAS FUENTES BASE

Fuente	Descripción	URL / Referencia
MITRE CAPEC v3.9	Catálogo oficial de patrones de ataque	https://capec.mitre.org
ENISA ETL 2025	European Threat Landscape 2025	https://enisa.europa.eu
INCIBE 2025	Estadísticas de incidentes España 2025	https://incibe.es
NIS2 (UE) 2022/2555	Directiva de seguridad redes e información	EUR-Lex
ENS RD 311/2022	Esquema Nacional de Seguridad	BOE-A-2022-7191
DORA 2022/2554	Digital Operational Resilience Act	EUR-Lex
NIST CSF 2.0	Cybersecurity Framework 2.0 (2024)	https://nist.gov/cyberframework
NIST SP 800-55r2	Performance Measurement Guide	https://csrc.nist.gov
NIST AI 100-2e2025	Adversarial Machine Learning Taxonomy	https://csrc.nist.gov
NIST FIPS 203/204/205	Post-Quantum Cryptography Standards	https://csrc.nist.gov
ISO/IEC 27001:2022	Information Security Management	ISO.org
ISO/IEC 42001:2023	AI Management Systems	ISO.org
IEC 62443	Industrial Cybersecurity	IEC.ch

Kit GQM+PRAGMATIC CAPEC-ESP · Documento G: README · Versión 1.0 · Abril 2026

Licencia: CC BY-NC-SA 4.0 · Contacto para consultas académicas y de implementación: ver encabezado de la institución distribuidora